

Quantum Computing in Cryptography: Post-Quantum Migration Strategies, Risk Assessment, and Enterprise Preparedness for Critical Infrastructure

You

July 25, 2026

1 Introduction

Quantum computing presents a transformational risk to contemporary cryptography, and the security of critical infrastructure depends on a deliberate, auditable transition to post-quantum cryptography. This report synthesizes authoritative guidance and pragmatic industry practice to deliver an end-to-end framework for Quantum-Resistant Cryptography (PQC) governance, risk assessment, and enterprise preparedness. It addresses the full spectrum of enterprise reality—across on-premise, cloud, OT/ICS, and edge environments—where cryptographic assets reside in software libraries, PKI certificates, hardware security modules (HSMs), cryptographic devices, and third-party integrations.

The introduction of PQC standards (NIST PQC efforts, national guidance, CISA viewpoints) requires a rigorous inventory, exposure modeling, and a phased migration that preserves continuity of service while tightening governance, budgeting, vendor dependencies, and testing criteria. This report articulates: (1) a scalable end-to-end asset mapping methodology to identify systems-dependent on classical cryptography vulnerable to quantum attacks; (2) data sources, tooling, and data models to inventory crypto libraries, PKI infrastructures, hardware security modules (HSMs), and related hardware and to classify assets by cryptographic exposure (RSA, ECC, DSA, AES, SHA families) and identify outliers; (3) rigorous verification of PKI, credential stores, and HSMs, including auditing legacy OT/ICS in air-gapped environments; (4) cataloging of vendor and third-party dependencies and testing of cryptographic integration; (5) alignment with PQC governance and standards, including governance structures and regulatory expectations; and (6) a risk-driven migration plan with phase gates, milestones, acceptance criteria, and metrics.

Beyond asset and risk management, the report addresses data privacy, supply chain integrity, and OT/ICS lifecycle considerations, delivering a concrete, auditable pathway to resilient, compliant PQC adoption for critical infrastructure. [1, 5, 3]

2 End-to-End Asset Mapping: Scope, Data Sources, and Tooling

2.1 Scope and boundaries

The asset mapping effort must span: the enterprise data center, cloud services, OT/ICS environments (including air-gapped and semi-isolated networks), and edge devices where cryptographic assets reside in software libraries, PKI certificates, hardware security modules (HSMs), cryptographic devices, and third-party integrations. A scalable approach recognizes that crypto assets permeate servers, services, and devices, from containerized microservices with embedded crypto to legacy field devices with long lifecycles in OT networks. The multi-domain scope is essential to capture RSA, ECC, DSA cryptographic algorithms and AES/SHA families across all layers of the stack [5, 3, 1].

2.2 Data sources and tooling to inventory crypto assets

- Software crypto libraries and modules: identify all cryptographic libraries embedded within applications and containers, including algorithmic suites and supported key sizes. This requires a software composition analysis (SCA) process integrated into CI/CD to catalog cryptographic primitives, default configurations, and deprecated or weak algorithms. The governance framework benefits from formal inventory and testing traces that align with industry best practices [?, ?, 12].

- PKI certificates and trust stores: establish a comprehensive inventory of PKI infrastructures, CA hierarchies, intermediate and root certificates, cross-certificates, and certificate lifetimes. This inventory should be integrated with certificate lifecycle management tools to surface exposure patterns, such as long-lived certificates that threaten agility or lack post-quantum protection, and to identify abrupt reissuance needs when PQC implementations are required. Regulator-facing guidance emphasizes PKI and credential store integrity as a pillar of PQC readiness [4, 5].

- HSMs and cryptographic devices: catalog HSM instances, firmware versions, cryptographic modules, and access controls. HSM inventories must be cross-validated against cryptographic libraries and PKI assets to ensure end-to-end coverage and to identify devices that may be constrained by future PQC acceleration or key-management changes [5, 9, ?].

- Third-party dependencies and vendor integrations: map external cryptographic services, libraries, and hardware integrations that influence exposure and testing. This includes cloud-provided KMS, external cryptographic modules, and vendor-provided cryptographic services. The governance literature emphasizes supplier risk and CBOM management as part of a comprehensive PQC program [7, ?].

2.3 Data models, schemas, and tooling objectives

- Inventory schema: an asset-centric schema that ties cryptographic exposure to asset inventory—asset identifiers, platform type (IT, cloud, OT), cryptographic libraries, certificates, HSMs, cryptographic devices, and third-party dependencies; fields for algorithm families, key sizes, and exposure status. The schema should be designed to support phase gates and risk scoring (see Section 4).

- Data sources integration: the tooling stack should ingest data from software inventories (SCA), certificate inventories, device asset catalogs, HSM management consoles, and supplier CBOM feeds. Data normalization and lineage tracking are essential to support reproducibility, auditing, and reporting.

- Risk registers and testing plans: the data model should support linking assets to risk registers, test plans, and phase-gate criteria with traceability to executive KPIs.

2.4 Operationalizing across domains

To ensure consistent coverage across enterprise, cloud, OT/ICS, and edge, governance teams should adopt a centralized yet domain-aware data model. This ensures that OT/ICS air-gapped assets can be included in the inventory via asset discovery on adjacent networks, asset registries, and maintenance records, while preserving the sanctity of air gaps where direct discovery is not feasible. Regulators recognize the importance of cross-domain visibility to ensure continuity and timeliness of PQC adoption [3].

3 Classifying Assets by Cryptographic Exposure

3.1 Exposure taxonomy

Each asset should be classified by cryptographic exposure across a standardized set of algorithms and key sizes:

- RSA, ECC, DSA exposures by current key sizes and estimated resistance to quantum attacks (e.g., RSA-2048, RSA-3072; ECDSA over P-256, P-384; DSA 2048) with posture toward imminent quantum vulnerability.
- AES (128, 192, 256) and SHA family exposure given their roles in symmetric-key and hash-based integrity/signature schemes, including potential need for longer-lived keys or new KMS integration strategies in PQC contexts.

- The determination of exposure should be grounded in a risk model that weighs the asset's criticality, crypto-lifecycle stage, and whether the asset supports post-quantum alternatives in its stack

or relies on legacy primitives. This classification approach aligns with formal guidance calling for an inventory of cryptographic exposure and identification of outliers and high-risk components [5, 4, ?].

3.2 Outlier and high-risk identification

- Outliers include assets that rely on legacy cryptographic configurations (e.g., RSA-1024, ECC curves considered weak by current guidance, outdated DSA implementations), or assets with cross-domain exposure that would disrupt business continuity if PQC-driven changes are required without equivalent migration support.

- High-risk components include PKI infrastructures with root certificates or cross-certificates that span critical business processes, devices in OT environments with limited upgradability, or cloud services whose cryptographic posture is controlled by external providers with timelines not aligned to enterprise migration gates [3, 5].

4 Verifying PKI Infrastructures, Credential Stores, and HSMs

4.1 PKI verification and credential stores

- Verification involves validating CA hierarchies, certificate validity windows, and revocation status, ensuring consistency between PKI policy and operational practice, and confirming that credential stores (soft-token vaults, HSM-backed stores) are in alignment with policy and regulatory expectations. Formal guidance highlights PKI governance and auditability as central to PQC readiness [4, 5].

4.2 HSMs and cryptographic devices

- HSMs must be cataloged, versioned, and governed by a key-management plan that accommodates the impending PQC transition. Management consoles, firmware versions, and access controls should be tracked, with change management integrated into the overall PQC governance program. Industry guidance and regulator-focused frameworks emphasize HSM governance, testing, and CBOM considerations as part of a robust PQC program [5, ?].

4.3 OT/ICS legacy equipment in air-gapped environments

- Legacy OT/ICS devices—often in air-gapped or semi-isolated networks—pose unique verification challenges. Auditing such equipment requires domain-specific strategies, including asset discovery via maintenance records, network attachment points, and indirect validation of cryptographic exposure, combined with robust governance around exception handling and migration sequencing. Regulatory guidance highlights OT considerations in PQC adoption and the need for auditable processes in these environments [3, ?].

5 Cataloging Vendor and Third-Party Dependencies; Testing Cryptographic Integration

5.1 CBOM and supplier risk

- A complete CBOM is required for cryptographic components and services down to the cryptographic libraries and HSM firmware. Strong CBOM management and vendor risk oversight support traceability from policy to deployment, ensuring that third-party cryptographic modules used by enterprise systems align with PQC timelines and regulatory expectations. The governance literature emphasizes supplier risk management and CBOM for PQC readiness and ongoing resilience [7, ?].

5.2 Testing cryptographic integration

- Testing plans should encompass interoperability with existing cryptographic suites, performance evaluations, and end-to-end validation of cryptographic paths across PKI lifecycles, HSMs, and external

services. Enterprise migration frameworks emphasize lab-to-prod validation, cross-platform interoperability, and end-to-end testing to ensure a controlled and auditable transition [?, 8].

6 Alignment with PQC Standards and Governance Considerations

6.1 Governance structures and regulatory expectations

- The enterprise program should align with formal PQC governance guidance from national and international authorities, including NIST PQC processes, ETSI, and ISO considerations, and be designed to provide auditable evidence packages (models, proofs, test vectors, reproducible builds, lab-to-prod traceability) suitable for regulator review. The White House guidance and CISA OT PQC materials provide a regulatory anchor for governance constructs and program milestones; industry frameworks reinforce the need for governance artifact development and accountability across vendor relationships and supply chains [1, 3, 5, 7].

6.2 Phase-gates, budget, vendor dependencies, and testing criteria

- A phased migration approach with clear gates—inventory complete; exposure model validated; pilot PQC prototyping; OT/ICS compliance checks; vendor remediation; enterprise-wide rollout—enables governance to manage budget, vendor dependency, and testing criteria. Industry literature emphasizes phase-gate criteria, budgeting impulses, and vendor governance as essential to successful PQC adoption [?, ?].

7 Phased Migration: Governance, Budgeting, and Testing Criteria

7.1 Phase 0 — Discovery and governance design

- Milestones: complete enterprise-wide inventory (software crypto libraries, PKI and credential stores, HSMs, cryptographic devices, and critical third-party dependencies); establish data models; define exposure taxonomy; implement initial governance structure (roles, decision rights, committees). Acceptance criteria: inventory coverage across enterprise, cloud, OT/ICS, and edge; baseline risk scoring framework; draft policy and CBOM governance.

- Metrics: percentage of assets discovered; coverage of critical cryptographic assets (RSA, ECC, DSA, AES, SHA); number of high-risk components identified; time-to-discovery. Accepted by: C-suite and risk committees.

- Data sources and tooling: SCA feeds, certificate inventories, HSM inventories, OT asset registries, supplier feed integration, and CBOM sources; align with official PQC guidance for governance and inventory [4, 5, 1].

7.2 Phase 1 — Exposure modeling and governance maturation

- Milestones: validated exposure model across RSA/ECC/DSA/AES/SHA families; vendor-risk assessment completed; OT/ICS risk posture documented; initial policy drafts; governance body operational; lab-to-prod test plan defined.

- Acceptance criteria: formal exposure classification for all critical assets; remediation plan prioritized by risk; evidence artifacts defined (inventory schema, risk registers, testing plans); phased governance dashboards established.

- Metrics: time to complete exposure classification per asset; share of assets with quantum-risk remediation plans; number of high-risk items prioritized in Phase 1.

7.3 Phase 2 — Lab prototyping and OT/ICS testing

- Milestones: PQC lab prototypes implemented with representative workloads; co-existence testing with legacy cryptographic paths; initial key-management adjustments; PKI re-issuance and HSM firmware test cycles; air-gapped OT/ICS testing results documented.
- Acceptance criteria: demonstrated interoperability, performance envelopes, and stability in test environments; documentation of risk mitigations and rollback plans; audit artifacts for major systems.
- Metrics: latency impact and throughput under PQC scenarios; number of devices requiring remediation; defect density in lab-to-prod tests.

7.4 Phase 3 — Pilot deployments and governance refinement

- Milestones: limited production pilot in non-critical or isolated segments; vendor-supplied PQC artifacts deployed; end-to-end governance artifacts previewed for regulators; change-management and vulnerability-management integration tested.
- Acceptance criteria: successful pilot with minimal business impact; regulatory artifacts in place; vendor-change control processes validated; resilience metrics demonstrated.
- Metrics: pilot success rate; mean time to identify and remediate PQC issues; cost and schedule variance.

7.5 Phase 4 — Enterprise deployment and sustainment

- Milestones: enterprise-wide PQC deployment; updated PKI, KMS, and HSM alignment; incident-response playbooks updated; disaster-recovery exercises updated for PQC paths.
- Acceptance criteria: full coverage with approved governance artifacts; compliance readiness; demonstrated resilience against PQC-related scenarios; measurable ROI within 12–24 months.
- Metrics: percentage of devices migrated; time-to-match SLAs for PQC updates; audit findings.

7.6 Phase 5 — Optimization, governance maturity, and continuous improvement

- Milestones: continuous monitoring, periodic re-validation of exposure, and alignment with evolving standards; supplier risk management refinement; data privacy and supply chain safeguards integrated with PQC governance.
- Metrics: governance-cycle completion rate; number of policy updates in response to standard changes; residual risk trending downward; operational resilience metrics.

8 Milestones, Acceptance Criteria, and Metrics

8.1 Concrete milestones and gates

- Gate 0: Inventory completeness; policy baseline defined; risk scoring framework in place.
- Gate 1: Exposure model validated; remediation backlog prioritized; lab-to-prod test plan with defined acceptance criteria.
- Gate 2: Pilot PQC implementations in controlled environments; interoperability and performance validated; change-management integration demonstrated.
- Gate 3: Partial production deployment in non-critical segments; regulator-facing artifacts compiled; readiness for broader rollout.
- Gate 4: Full enterprise deployment; audit trails, evidence packages, and governance dashboards in operation; continuous improvement loop established.

8.2 Acceptance criteria and metrics

- Coverage metrics: proportion of assets discovered and classified; proportion of cryptographic assets with exposure assessment.
- Testing metrics: lab-to-prod test pass rate; interoperability success rate; performance overhead measurements.
- Governance metrics: presence of policy artifacts; evidence packages; board-level dashboards; audit-readiness.
- Operational metrics: incident-response readiness; disaster-recovery plan alignment; change-management integration success.

9 Data Privacy, Supply Chain Integrity, and OT/ICS Lifecycle

9.1 Data privacy safeguards

- In PQC-enabled environments, cryptographic data handling must reflect privacy-by-design principles. The governance model should ensure that sensitive data exposure is minimized in all inventories and analytic datasets, with access controls, data minimization, and encryption where appropriate. Regulatory-aligned controls should be embedded in the governance framework, particularly for data-handling in cloud and cross-border contexts [3].

9.2 Supply chain integrity

- Vendor risk management and CBOM governance must be integrated into the PQC program. This includes third-party cryptographic module validation and ongoing supplier risk monitoring to ensure that the cryptographic supply chain remains trustworthy throughout the migration lifecycle [7, ?].

9.3 OT/ICS lifecycle considerations

- OT/ICS environments demand careful lifecycle management for devices with long lifespans and constrained upgrade windows. Governance must accommodate safe operating windows, segmentation, and rigorous testing of cryptographic transitions without compromising safety or uptime. Doctrines from regulator guidance emphasize OT PQC considerations and governance artifacts necessary for auditable compliance across IT and OT boundaries [3, 18].

9.4 Edge and remote environments

- Edge devices and hybrid deployments require scalable, edge-friendly instrumentation for inventory and testing. The governance program should embed edge-appropriate data collection, fleet management, and remote attestation where feasible to maintain a unified PQC posture while accommodating local constraints [?, 5].

10 Governance Architecture and Organizational Roles

10.1 Governance layers and decision rights

- A multi-tier governance construct should be instituted, including: - Executive Steering Committee (policy direction, budgets, regulator liaison). - PQC Governance Council (policy management, crypto-suite selection, vendor oversight, phase gates). - Asset-Centric Risk Boards (risk scoring, asset remediation prioritization, stage-based acceptance). - OT/ICS Compliance Council (OT-specific risk mitigation, device lifecycle considerations, safe-operating window orchestration). - Security Operations and Change Management (incidents, vulnerability management, patching). - Legal and Regulatory Affairs (audit readiness, evidence packages, regulatory submissions) [1, 5, 7].

10.2 Artifacts and dashboards

- Policy outlines, risk registers, CBOM catalogs, evidence packages, and executive dashboards to provide regulator-ready artifacts. Industry pieces emphasize artifact-centric governance and auditability, including lab-to-prod traceability, reference implementations, and reproducible environments [8, 9, ?].

11 Pragmatic Considerations for Rollout and Long-Term Sustainability

11.1 Resource and budget planning

- A disciplined, phased budget plan aligns with governance gates and standardization timelines, ensuring that the organization can absorb costs associated with inventory expansion, lab testing,

PKI/migration, and vendor remediation. The literature consistently highlights budgeting as a critical dimension of enterprise PQC programs and underlines the need for governance to own the budget line items, including CBOM and supplier risk management [?, ?].

11.2 Testing and verification discipline

- Verification must incorporate a layered approach: algorithm design verification, implementation-level testing, compiler/toolchain checks, and runtime/client-server interoperability. The formal verification and audit-readiness emphasis in enterprise-focused sources provides a strong blueprint for evidence packages and artifact catalogs that support regulator review [8, 15].

11.3 Interoperability and coexistence with legacy systems

- Coexistence with legacy cryptographic paths is a design constraint; the plan should incorporate a co-existence window, ensuring progressive migration that minimizes disruption. Industry sources emphasize the need for a carefully staged migration that preserves service continuity and provides a clear path to post-quantum cryptography without abrupt deprecation of existing cryptographic stacks [?, ?].

11.4 Data privacy and supply chain risk

- Data privacy and supply chain risk must be integrated into the security architecture with ongoing risk assessment, vendor monitoring, and auditable traceability that regulators can review. The regulatory and governance literature consistently points to these dimensions as essential to enterprise PQC programs [4, ?].

12 Concrete Artifacts and Templates (Phase-Ready, Phase-Gate Oriented)

- Inventory schema blueprint (asset, domain, cryptographic exposure, algorithms, key sizes, asset criticality, vendor, CBOM linkage, phase-gate status).
- Data model design and data dictionaries (for ease of data governance and reproducibility).
- Risk register templates (likelihood, impact, exposure, remediation plan, owner, and due dates).
- Testing plans and evidence catalogs (unit tests, integration tests, interoperability tests, performance benchmarks, test vectors, reproducible builds).
- Phase-gate criteria templates (milestones, acceptance criteria, responsible owners, sign-off workflows).
- Governance artifacts (policy outlines, committee charters, dashboards, audit evidence packs, lab-to-prod traceability matrices).

13 Executive-Level Perspective: Metrics, Roadmap, and Outcome

- The program is designed to deliver a regulated, auditable transition to PQC by aligning with national strategy and industry best practices, while preserving business continuity across IT and OT. The phased approach—rooted in inventory, exposure modeling, lab testing, pilot deployment, and enterprise rollout—creates a defensible migration governed by well-defined acceptance criteria, risk scoring, and regulator-ready evidence packages. The governance model provides a layered decision framework with executive oversight, domain-specific committees, and operational groups that coordinate change management, vulnerability management, and incident response. This structure ensures that the enterprise can respond to shifting regulatory expectations, evolving PQC standards, and vendor-delivery realities while maintaining service levels and data integrity [1, 5, 3, 7, ?, 12].

14 Conclusion

A disciplined, end-to-end PQC governance program is indispensable for a modern enterprise that spans on-prem, cloud, OT/ICS, and edge environments. By establishing a scalable asset-mapping method-

ology, a robust data-model framework, and a rigorous exposure classification aligned to RSA, ECC, DSA, AES, and SHA families, the organization can identify and prioritize high-risk components for phased remediation. Verifying PKI infrastructures, credential stores, and HSMS, while auditing legacy OT/ICS equipment in air-gapped contexts, becomes a repeatable, auditable practice that supports regulator expectations. The program must also codify vendor dependencies, cryptographic integrations, and supply-chain resilience within a governance construct that is explicit about roles, decision rights, and phase gates. The outcome is an auditable, risk-weighted PQC migration that preserves continuity of service, reduces quantum-exposure risk, and positions the organization to meet evolving national guidance and international standards—while delivering measurable improvements in governance maturity, risk posture, and operational resilience.

References

- [1] White House, Securing the Nation Against Advanced Cryptographic Attacks, <https://www.whitehouse.gov/presidential-actions/2026/06/securing-the-nation-against-advanced-cryptographic-attacks>
- [2] Center for Cybersecurity Policy, Strategy to Implementation (White House) – Strategy/Implementation (Policy context), <https://www.centerforcybersecuritypolicy.org/insights-and-research/from-strategy-to-implementation-the-white-house-accelerates-the-federal-transition-to-post-quantum>
- [3] CISA OT PQC 508, Post-Quantum Considerations for Operational Technology (508), <https://www.cisa.gov/sites/default/files/2024-10/Post-Quantum%20Considerations%20for%20Operational%20Technology%20%28508%29.pdf>
- [4] CISA PQC product categories, <https://www.cisa.gov/resources-tools/resources/product-categories-technologies-use-post-quantum-cryptography-standards>
- [5] NIST NCCOE Migration to PQC, <https://www.nccoe.nist.gov/applied-cryptography/migration-to-pqc>
- [6] NIST NCCOE Migration to PQC (additional), <https://pages.nist.gov/nccoe/migration-post-quantum-cryptography>
- [7] Cloud Security Alliance Enterprise ROA, <https://labs.cloudsecurityalliance.org/research/strategic-post-quantum-cryptography-migration-enterprise-roa>
- [8] Chainscore Labs PQC Compliance and Audit Framework, <https://www.chainscorelabs.com/en/guides/quantum-resistance-and-future-cryptography/pqc-for-defi-security/setting-up-a-pqc-compliance-and-audit-framework>
- [9] ETSI SOUPPAYA NIST_SOUPPAYA.pdf, https://docbox.etsi.org/Workshop/2024/05_QuantumSafeCryptoConference/TECHNICAL_TRACK/S3_MIGRATION/NIST_SOUPPAYA.pdf
- [10] ETSI/NIST SOUPPAYA, https://docbox.etsi.org/Workshop/2024/05_QuantumSafeCryptoConference/TECHNICAL_TRACK/S3_MIGRATION/NIST_SOUPPAYA.pdf
- [11] Encryption Consulting PQC Migration Frameworks, <https://www.encryptionconsulting.com/pqc-migration-frameworks-updates-june-2026>
- [12] PQC Frameworks (pqcframework.com), <https://pqcframework.com>
- [13] Post-Quantum Migration Framework v2, <https://postquantum.com/security-pqc/pqc-migration-framework-v2>
- [14] Post-Quantum Migration Framework Survey (June 2026), <https://pqcframework.com/pqc-migration-frameworks-survey>
- [15] Intel PQC Readiness, <https://www.intel.com/content/www/us/en/security/post-quantum-cryptography-readiness.html>

- [16] CSA Enterprise ROA (ForwardEdge/Isidore variant), <https://www.forwardedge.ai/pages/isidore-pqc-readiness>
- [17] Post-Quantum OT PQC Challenges, <https://postquantum.com/post-quantum/ot-pqc-challenges>
- [18] Center for Cybersecurity Policy – Strategy/Implementation (Policy context), <https://www.centerforcybersecuritypolicy.org/insights-and-research/from-strategy-to-implementation-the-white-house-accelerates-the-federal-transition-to-post-quantum>
- [19] ETSI/NIST SOUPPAYA, https://docbox.etsi.org/Workshop/2024/05_QuantumSafeCryptoConference/TECHNICAL_TRACK/S3_MIGRATION/NIST_SOUPPAYA.pdf
- [20] IndustrialCyber OT PQC Coverage, <https://industrialcyber.co/features/industrial-systems-face-structural-gap-as-quantumrisks-drive-urgency-for-crypto-agility-and-post-quantum>
- [21] CISA Post-Quantum Considerations for OT (508), [https://www.cisa.gov/sites/default/files/2024-10/Post-Quantum%20Considerations%20for%20Operational%20Technology%20\(%28508%29\).pdf](https://www.cisa.gov/sites/default/files/2024-10/Post-Quantum%20Considerations%20for%20Operational%20Technology%20(%28508%29).pdf)
- [22] Center for Cybersecurity Policy – Strategy/Implementation (Policy context), <https://www.centerforcybersecuritypolicy.org/insights-and-research/from-strategy-to-implementation-the-white-house-accelerates-the-federal-transition-to-post-quantum>
- [23] ETSI/NIST SOUPPAYA, https://docbox.etsi.org/Workshop/2024/05_QuantumSafeCryptoConference/TECHNICAL_TRACK/S3_MIGRATION/NIST_SOUPPAYA.pdf
- [24] Intel PQC Readiness, <https://www.intel.com/content/www/us/en/security/post-quantum-cryptography-readiness.html>